

Adattudomány MSc – záróvizsga tételek

Bence Dáné

2026

Tartalomjegyzék

1. Az adattudomány elméleti háttéréhez kapcsolódó alapismeretek.	1
1.1. 1. tétel: információbiztonsági alapok	1
1.2. 2. tétel: hitelesítés, nyomkövethetőség és biztonságos üzemeltetés .	5
1.3. 3. tétel: gépi tanulási alapismeretek	15
2. Az adattudomány gyakorlati háttéréhez kapcsolódó alapismeretek.	20

1. Az adattudomány elméleti háttéréhez kapcsolódó alapismeretek.

1.1. 1. tétel: információbiztonsági alapok

Az információbiztonság alapfogalmai (CIA-hármas); a kiberbiztonság eszközei és céljai; kártékony programok, támadási technológiák; hozzáférés-szabályozás (DAC, MAC, RBAC, ABAC, CBAC); hozzáférés-szabályozás elosztott rendszerekben.

Információbiztonsági alapfogalmak

Az információbiztonság célja az információ és az információs rendszerek védelme a jogosulatlan hozzáféréssel, módosítással, megsemmisítéssel, szolgáltatás-kieséssel és visszaéléssel szemben. A klasszikus alapmodell a **CIA-hármas**:

- **Confidentiality – bizalmasság:** az információ csak jogosult személy, folyamat vagy rendszer számára legyen hozzáférhető. Példa: titkosítás, hozzáférés-vezérlés, jogosultságkezelés.
- **Integrity – sértetlenség:** az adat pontos, teljes és jogosulatlanul nem módosított. Példa: hash, MAC, digitális aláírás, tranzakciós naplózás.
- **Availability – rendelkezésre állás:** a jogosult felhasználók a szükséges időben elérik a rendszert vagy szolgáltatást. Példa: redundancia, mentés, terheléselosztás, DoS-védelem.

Ezeket gyakran kiegészítik további biztonsági célokkal: **hitelesség, elszámoltathatóság, nyomonkövethetőség és letagadhatatlanság**. A hitelesség azt jelenti, hogy a forrás vagy entitás valóban az, akinek állítja magát; az elszámoltathatóság és nyomonkövethetőség pedig azt, hogy utólag rekonstruálható, ki mit tett.

A kiberbiztonság céljai és eszközei

A kiberbiztonság az információs rendszerek, hálózatok, alkalmazások, hardverek, adatok és szolgáltatások védelmét jelenti. A védelem nem csak technológia: emberek, folyamatok és szervezeti szabályok együttese.

Fő célja a szervezet működésének, adatainak és szolgáltatásainak védelme úgy, hogy a kockázatok elfogadható szintre csökkenjenek. Ez nem azt jelenti, hogy minden támadás teljesen kizárható, hanem azt, hogy a támadási felületet csökkentjük, a hibákat időben felismerjük, és incidens esetén gyorsan helyreállítunk. Ennek eszközei a megelőző kontrollok (például erős hitelesítés, titkosítás, jogosultságkezelés), a detektív kontrollok (naplózás, monitorozás, IDS/IPS), valamint a korrektív kontrollok (mentés, incidenskezelés, helyreállítás). A gyakorlatban rétegzett védelemre van szükség, mert egyetlen eszköz hibája esetén a többi kontrollnak kell csökkentenie a kárt.

Terület	Tipikus eszközök és célok
Rendszerbiztonság	Operációs rendszer jogosultságai, folyamat- és memóriavédelem, virtualizáció, izoláció, Trusted Execution Environment.
Kriptográfia	Titkosítás, hash, MAC, digitális aláírás, kulcskezelés, tanúsítványok.
AAA	Hitelesítés, feljogosítás, naplózás/elszámoltathatóság.
Hálózatbiztonság	Tűzfal, IDS/IPS, VPN, DMZ, szegmentáció, biztonságos protokollok.
Hardverbiztonság	Root of trust, TPM/HSM, biztonságos kulcstárolás, valódi véletlenszám-generátor, PUF.
Szoftverbiztonság	Secure SDLC, threat modeling, secure coding, review, tesztelés, dependency management.
Emberi és szervezeti védelem	Usable security, képzés, szabályzatok, kockázatmenedzsment, GDPR, NIS2.

Kártékony programok és támadási technológiák

Kártékony program minden olyan szoftver, amelyet a támadó jogosulatlan hozzáférés, adatlopás, károkozás, rejtőzködés vagy zsarolás céljából használ.

A kártékony programok gyakran nem önmagukban, hanem egy támadási lánc részeként jelennek meg: bejutás után perzisztenciát építenek ki, jogosultságot növelnek, oldalirányban mozognak a hálózatban, majd adatot lopnak, rombolnak vagy zsarolnak. A modern támadások sokszor technikai és emberi elemeket kombinálnak,

például phishinggel szerzik meg a belépési pontot, majd sérülékenység-kihasználással terjeszkednek tovább. Védekezésben fontos a naprakész patch-elés, a végpontvédelem, a jogosultságok minimalizálása, a hálózati szegmentáció, a biztonsági mentés és a felhasználók képzése. A ransomware elleni védelemben különösen lényeges az offline vagy elkülönített mentés, mert a támadó gyakran a mentéseket is megpróbálja törölni vagy titkosítani.

- **Vírus:** gazdaprogramhoz kapcsolódik, annak futásával terjed.
- **Féreg:** önállóan, hálózaton keresztül terjedhet.
- **Trójai:** hasznos programnak álcázza magát, de rejtett káros funkciót tartalmaz.
- **Ransomware:** titkosítja vagy zárolja az adatokat, majd váltságdíjat követel.
- **Spyware/keylogger:** információt, jelszót, billentyűleütést gyűjt.
- **Rootkit/backdoor:** tartós rejtett hozzáférést biztosít a támadónak.
- **Botnet malware:** kompromittált gépeket központi vezérlés alá von, például DDoS-hoz vagy spamhez.

Tipikus támadási technológiák:

- **Social engineering és phishing:** a felhasználó megtévesztése hitelesítő adatok vagy művelet kicsalására.
- **Brute force és credential stuffing:** jelszavak próbálgatása vagy kiszivárgott jelszavak újrafelhasználása.
- **DoS/DDoS:** a rendelkezésre állás támadása túlterheléssel.
- **Man-in-the-middle:** kommunikáció lehallgatása vagy módosítása két fél között.
- **Injection:** például SQL, command vagy script injection, ahol a támadó bemenetként kódot juttat a rendszerbe.
- **Privilege escalation:** alacsonyabb jogosultságból magasabb jogosultság megszerzése.
- **Exploit és sérülékenység-kihasználás:** szoftverhiba célzott kihasználása.

Hozzáférés-szabályozás alapjai

A hozzáférés-szabályozás célja annak eldöntése, hogy egy **alany** (felhasználó, folyamat, szolgáltatás) végrehajthat-e egy **műveletet** egy **objektumon** (fájl, adatbázis, API, szolgáltatás). A döntés alapja egy szabályrendszer, azaz **policy**.

Az AAA-modell:

- **Authentication – hitelesítés:** ki kezdeményezte a kérést?
- **Authorization – feljogosítás:** jogosult-e a kért műveletre?
- **Accounting – naplózás:** mi történt, mikor, milyen eredménnyel?

Hozzáférés-szabályozási komponensek:

- **PEP – Policy Enforcement Point:** kikényszeríti a döntést, például API gateway vagy operációs rendszer.
- **PDP – Policy Decision Point:** meghozza az engedélyezési döntést.
- **PIP – Policy Information Point:** attribútumokat szolgáltat, például szerepkör, eszközállapot, idő, hely.
- **Audit log:** a döntés és művelet nyoma.

Hozzáférés-szabályozási modellek

A hozzáférés-szabályozási modellek azt határozzák meg, milyen elv alapján születik meg az engedélyezési döntés. A választott modell mindig kompromisszum a rugalmasság, az adminisztrálhatóság és a biztonsági szigor között: egy kis csoportban elég lehet a DAC, nagyvállalati környezetben tipikus az RBAC, míg érzékeny vagy dinamikus rendszerekben gyakran ABAC vagy MAC szükséges. A legfontosabb általános elv a legkisebb jogosultság elve, vagyis az alany csak azt a hozzáférést kapja meg, amely a feladatához valóban szükséges. A modellek a gyakorlatban keveredhetnek is, például egy vállalati rendszer szerepköröket használ, de bizonyos műveleteket időhöz, eszközállapothoz vagy kockázati szinthez köt.

Modell	Lényege	Tipikus használat / megjegyzés
DAC	A tulajdonos dönt arról, ki férhet hozzá az objektumhoz.	Rugalmas, de könnyen túlengedélyezhető; klasszikus fájlrendszer-jogosultságok.
MAC	Központilag meghatározott címkék és biztonsági szintek alapján dönt.	Katonai/államigazgatási környezet; a tulajdonos nem írhatja felül.
RBAC	Jogosultságok szerepkörök-höz tartoznak, felhasználók szerepköröket kapnak.	Vállalati rendszerek; munkakör alapú jogosultságkezelés.
ABAC	Felhasználó-, erőforrás- és környezeti attribútumok alapján dönt.	Finomabb szabályok: idő, hely, eszközállapot, kockázati szint.
CBAC	A végrehajtott kód eredete, identitása, hash-e vagy aláírása alapján dönt.	Mobilkód, sandbox, futtatható állományok kontrollja.

Fontos kiegészítés: a szabályozás megvalósítható hozzáférési mátrixszal, ACL-lel vagy képességlistával. Az **ACL** objektumonként tárolja, ki mit tehet; a **capability** alanyonként tárolja, milyen objektumhoz milyen joga van.

Hozzáférés-szabályozás elosztott rendszerekben

Elosztott rendszerben a felhasználók, szolgáltatások és erőforrások több gépen, hálózati zónában vagy szervezetben lehetnek. Ezért a hozzáférési döntéshez szükséges identitást, attribútumokat, szabályokat és bizonyítékokat biztonságosan kell továbbítani.

Fő kihívások:

- **Bizalmi határok:** más szervezet vagy szolgáltatás állításait kell elfogadni.
- **Központi vs. lokális döntés:** központi policy könnyebben kezelhető, de kiesési pont lehet; lokális döntés skálázhatóbb, de inkonzisztens lehet.

- **Attribútumok frissessége:** szerepkör, jogosultság vagy token visszavonása gyorsan érvényesüljön.
- **Kommunikáció védelme:** titkosított, hitelesített csatorna szükséges.
- **Naplózás és audit:** több rendszer eseményeit kell időben és tartalmilag korrelálni.

Tipikus megoldások:

- **Kerberos:** jegyalapú, szimmetrikus kulcsos hitelesítés egy bizalmi tartományon belül.
- **SAML, OAuth2, OpenID Connect:** token/assertion alapú föderált identitás és hozzáférés webes és API-környezetben.
- **mTLS és tanúsítványok:** szolgáltatás-szolgáltatás kommunikáció kölcsönös hitelesítése.
- **Attribútum-alapú titkosítás:** az adat úgy titkosítható, hogy csak megfelelő attribútumokkal rendelkező kulcs birtokosa férjen hozzá.
- **Zero Trust szemlélet:** nincs automatikus bizalom belső hálózati pozíció alapján; minden hozzáférést hitelesíteni, autorizálni és naplózni kell.

Vizsgán mondható záró összefoglaló

Az 1-es tétel lényege, hogy az információbiztonság a bizalmasság, sértetlenség és rendelkezésre állás védelméből indul ki, de a modern rendszerekben hitelességre, elszámoltathatóságra és nyomonkövethetőségre is szükség van. A kiberbiztonság eszközei technikai, szervezeti és emberi kontrollokból állnak. A hozzáférés-szabályozás az AAA-modellre épül: először hitelesítünk, majd jogosultsági döntést hozunk, végül naplózunk. A DAC, MAC, RBAC, ABAC és CBAC különböző absztrakciós szinten szabályozza, ki, mit, milyen feltétellel tehet meg. Elosztott rendszerekben a fő probléma a bizalmi határok, a tokenek, attribútumok, policy-k és naplók konzisztens, biztonságos kezelése.

1.2. 2. tétel: hitelesítés, nyomonkövethetőség és biztonságos üzemeltetés

Hitelesítés, felhasználó-hitelesítés; hitelesítés elosztott rendszerekben; nyomonkövethetőség; biztonságos üzemeltetés és incidenskezelés; Monitor–Analyze–Plan–Execute–Knowledge (MAPE-K); rendeletek, szabványok.

A tétel helye az információbiztonságban

Az információbiztonság célja az információ és az információs rendszerek bizalmasságának, sértetlenségének, rendelkezésre állásának, hitelességének, elszámoltathatóságának és nyomonkövethetőségének biztosítása. A jelen tétel ezek közül főként a hitelességre, a hozzáférésmenedzsmentre, az események utólagos bizonyíthatóságára, valamint a biztonságos üzemeltetésre koncentrál.

A hozzáférésmenedzsment klasszikus felbontása az **AAA-modell**:

- **Authentication – hitelesítés:** annak ellenőrzése, hogy az entitás valóban az, akinek állítja magát.
- **Authorization – feljogosítás:** annak eldöntése, hogy a hitelesített entitás milyen erőforráshoz, milyen művelettel férhet hozzá.
- **Accounting – naplózás, elszámoltathatóság:** annak rögzítése, hogy ki, mikor, honnan, milyen műveletet hajtott végre, illetve ez milyen eredménnyel járt.

Vizsgán fontos különbséget tenni az *azonosítás*, a *hitelesítés* és a *feljogosítás* között. Az azonosítás pusztán az identitás megadása, például felhasználónévvel. A hitelesítés ennek alátámasztása, például jelszóval, tokennel vagy biometrikus adattal. A feljogosítás már az üzleti vagy biztonsági szabályok alapján dönt a hozzáférésről.

Hitelesítés és felhasználó-hitelesítés

Hitelesség és entitáshitelesítés A hitelesség azt fejezi ki, hogy valaminek a forrása az, amit megjelöltek, és tartalma nem módosult illetéktelenül. Két gyakori értelmezése:

- **Entitáshitelesítés:** egy felhasználó, szolgáltatás, eszköz vagy folyamat identitásának ellenőrzése.
- **Üzenethitelesítés:** annak ellenőrzése, hogy az üzenet adott forrásból származik és nem változott meg. Erre használható például MAC vagy digitális aláírás.

Felhasználó-hitelesítéskor a rendszer nem magát a személyt, hanem egy *hitelesítő adatot* ellenőriz. Ezért a hitelesítés biztonsága mindig függ attól, mennyire nehéz az adott hitelesítő adatot megszerezni, hamisítani, újrajátszani vagy kikényszeríteni.

Hitelesítési faktorok A hitelesítési módszerek alapvetően három fő faktorra épülnek:

- **Tudás alapú faktor:** amit a felhasználó tud, például jelszó, PIN, jelmondat.
- **Birtoklás alapú faktor:** amivel a felhasználó rendelkezik, például okoskártya, hardverkulcs, mobilalkalmazás, TOTP-token.
- **Biometrikus vagy inherens faktor:** ami a felhasználóra jellemző, például ujjlenyomat, írisz, arc, hang, gépelési ritmus.

A többfaktoros hitelesítés akkor erős, ha a faktorok egymástól független kompromittálási csatornákkal rendelkeznek. Például a jelszó és az SMS-kód két faktor ugyan, de SIM-csere, adathalászat vagy rosszindulatú mobilalkalmazás esetén egyszerre is sérülhetnek. Erősebb megoldás a hardveres biztonsági kulcs vagy a platform-hitelesítő, különösen ha a hitelesítés kriptográfiailag kötődik az adott szolgáltatás domainjéhez.

Jelszavas hitelesítés A jelszó előnye, hogy olcsó, egyszerűen bevezethető és nem igényel külön eszközt. Hátránya, hogy a felhasználók gyakran újrahasznosítják, gyenge jelszót választanak, vagy adathalász támadásban kiadják. A biztonságos jelszókezelés főbb elvei:

- A jelszavakat nem szabad nyílt szövegben tárolni; szózott, lassú, memóriaigényes jelszó-kivonatoló függvény használata szükséges.
- A jelszóhossz fontosabb, mint a mesterségesen bonyolult, de rövid összetételi szabályok.
- Támogatni kell a jelszókezelők használatát és tiltani kell az ismertén kiszivárgott jelszavakat.
- Kritikus rendszereknél jelszó önmagában nem elegendő, többfaktoros hitelesítés szükséges.

Tokenek, okoskártyák és tanúsítványok A birtoklás alapú hitelesítés egyik tipikus formája az okoskártya vagy hardveres token. Ezek gyakran kriptográfiai kulcsot tárolnak, amelyet a felhasználó nem tud közvetlenül kiolvasni, csak műveletet kérhet vele. A hitelesítés történhet kihívás-válasz protokollal: a szerver egy friss, egyszer használatos kihívást küld, a token pedig a privát kulccsal bizonyítja birtoklását. Így a privát kulcs nem kerül át a hálózaton.

Digitális tanúsítvány esetén egy hitelesítésszolgáltató köti össze a nyilvános kulcsot egy identitással. Ez gép-gép kommunikációban, VPN-ben, TLS-ben, közigazgatási vagy vállalati rendszerekben különösen fontos.

Biometrikus hitelesítés A biometria kényelmes, mert a felhasználónak nem kell jelszót megjegyeznie vagy külön eszközt hordania. Statikus biometria például az ujjlenyomat, írisz, retina vagy arc; dinamikus biometria például az aláírás, hang, gépelési ritmus vagy járásminta.

Biztonsági szempontból a biometria speciális: jelszóval ellentétben nem cserélhető könnyen, és adatvédelmi kockázatot hordoz. Emiatt a biometrikus sablont védeni kell, célszerű helyben, biztonságos hardveres tárolóban feldolgozni, és nem központi adatbázisban nyíltan tárolni. A biometrikus rendszerek hibái sem binárisak: beszélni kell hamis elfogadási arányról és hamis elutasítási arányról.

A hitelesítés tipikus támadásai A felhasználó-hitelesítést több támadási osztály fenyegeti:

- **Adathalászat:** a támadó hamis felületre irányítja a felhasználót, és megszerzi a hitelesítő adatot.
- **Credential stuffing:** korábban kiszivárgott jelszó-felhasználónév párok automatizált kipróbálása más szolgáltatásokon.
- **Brute force és szótáras támadás:** gyenge vagy kiszámítható jelszavak próbálgatása.
- **Replay támadás:** korábbi hitelesítési üzenet újrajátszása, ha nincs friss nonce, időbélyeg vagy munkamenet-kötés.
- **Session hijacking:** a hitelesítés után létrejött session token megszerzése.
- **MFA fatigue:** a felhasználó ismételt push-kérések hatására jóváhagy egy támadói belépést.

A védekezés réteges: erős jelszótárolás, MFA, adathalászatnak ellenálló hitelesítők, kockázatalapú belépésvizsgálat, eszköz- és helyfüggő anomáliafigyelés, rate limiting,

account logout, biztonságos session-kezelés és részletes naplózás.

Hitelesítés elosztott rendszerekben

Miért nehezebb elosztott környezetben? Elosztott rendszerben a szolgáltatások, felhasználók, identitásszolgáltatók és erőforrások több gépen, hálózati zónában, szervezetben vagy felhőszolgáltatásban helyezkednek el. Ilyenkor a hitelesítés problémái kibővülnek:

- a felek gyakran nem ugyanabban a bizalmi tartományban vannak;
- a hálózat nem tekinthető megbízhatónak;
- szükség van kölcsönös hitelesítésre, nemcsak a felhasználó, hanem a szerver oldalán is;
- a hitelesítési állapotot tovább kell vinni több szolgáltatás között;
- kezelni kell a tokenek élettartamát, visszavonását és továbbadását.

Az elosztott rendszerekben ezért gyakori a központi vagy föderált identitáskezelés: a felhasználó egy identitásszolgáltatónál hitelesít, majd a szolgáltatások megbíznak az identitásszolgáltató által kiadott jegyben, állításban vagy tokenben.

Kerberos A Kerberos klasszikus, szimmetrikus kulcsokra épülő hálózati hitelesítési protokoll. Célja, hogy a kliens és a szolgáltatás kölcsönösen hitelesíteni tudja egymást úgy, hogy a felhasználó jelszava vagy annak lenyomata ne menjen át a hálózaton.

Fő szereplők:

- **Kliens:** a felhasználó munkaállomása vagy folyamata.
- **Application Server:** az igénybe venni kívánt szolgáltatás.
- **Authentication Server (AS):** a felhasználó kezdeti hitelesítését végzi.
- **Ticket Granting Server (TGS):** szolgáltatói jegyeket ad ki.
- **Key Distribution Center (KDC):** az AS és TGS együttese.

A működés röviden:

1. A kliens az AS-től **Ticket Granting Ticketet** (TGT) kér.
2. Az AS a felhasználó jelszavából származtatott kulccsal titkosítva küldi vissza a TGT használatához szükséges session keyt.
3. Ha a felhasználó helyes jelszót adott meg, a kliens vissza tudja fejteni ezt, de a jelszó nem utazott a hálózaton.
4. A kliens a TGT-vel a TGS-től szolgáltatói jegyet kér.
5. A szolgáltatói jeggyel és egy rövid érvényességű authenticatorral fordul a konkrét szerverhez.
6. Kölcsönös hitelesítés esetén a szerver is bizonyítja, hogy ismeri a megfelelő session keyt.

A Kerberos erőssége a single sign-on jelleg és a jelszó hálózaton kívül tartása. Kockázata, hogy a KDC kiemelten kritikus komponens, a jegyek időhöz kötöttek, ezért pontos időszinkron kell, és a TGT megszerzése nagy értékű támadói cél.

OAuth 2.0 és OpenID Connect Az OAuth 2.0 elsősorban **felhatalmazási** keretrendszer: azt teszi lehetővé, hogy egy kliensalkalmazás a felhasználó erőforrásaihoz korlátozott hozzáférést kapjon anélkül, hogy a felhasználó jelszavát megkapná. Tipikus szereplők:

- **Resource Owner:** az erőforrás tulajdonosa, rendszerint a felhasználó.
- **Client:** az alkalmazás, amely hozzáférést kér.
- **Authorization Server:** hitelesít, hozzájárulást kezel, token-t ad ki.
- **Resource Server:** az API vagy szolgáltatás, amely a token-t ellenőrzi.

Az OAuth hozzáférési token-t ad ki, amely meghatározott hatókörrel és élettartammal használható. Az **OpenID Connect** erre épül, és hitelesítési réteget ad hozzá: az Authorization Server digitálisan aláírt ID token-t ad ki, amely állításokat tartalmaz a felhasználó identitásáról.

Fontos vizsgapont: az OAuth önmagában nem felhasználó-hitelesítési protokoll, hanem felhatalmazási keretrendszer. Ha bejelentkeztetésre használjuk, OpenID Connectre vagy más identitásrétegre van szükség.

Föderált identitás és SSO Föderált identitáskezelésnél egy szervezet vagy szolgáltatás megbízza egy külső identitásszolgáltatóban. A felhasználó az IdP-nél hitelesít, a szolgáltatás pedig aláírt állítás vagy token alapján dönt. Előnyei:

- központi felhasználó-életciklus-kezelés;
- kevesebb jelszó és kevesebb helyi fiók;
- egységes MFA és hozzáférési szabályok;
- könnyebb auditálhatóság.

Kockázatai:

- az identitásszolgáltató kiesése vagy kompromittálása nagy hatású;
- rosszul beállított redirect URI, token-validáció vagy aláírásellenőrzés súlyos sebezhetőség;
- túl hosszú token-élettartam vagy gyenge visszavonási mechanizmus támadói mozgásteret ad.

Hozzáférésvezérlés kapcsolódása A hitelesítés után a rendszernek el kell döntenie, hogy a hitelesített entitás mire jogosult. Gyakori modellek:

- **DAC:** a tulajdonos vagy felhasználó által vezérelt hozzáférés.
- **MAC:** központi, címkéken és biztonsági szinteken alapuló hozzáférés.
- **RBAC:** szerepkörök alapján adott jogosultságok.
- **ABAC:** attribútumok alapján hozott döntés, például felhasználói tulajdonság, eszközállapot, napszak, kockázati szint.

Modern rendszerekben gyakori a Zero Trust szemlélet: nincs automatikus bizalom belső hálózati pozíció alapján, minden hozzáférést folyamatosan hitelesíteni, autorizálni és naplózni kell.

Nyomonkövethetőség, naplózás és audit

A nyomonkövethetőség célja A nyomonkövethetőség olyan folyamatok és technikai megoldások összessége, amelyek az események bekövetkezése után lehetővé teszik a történetek rekonstruálását. Ide tartozik a rendszeres audit, a technikai logelemzés, a megfelelőségi ellenőrzés és az incidens utáni vizsgálat.

Egy jó naplózási rendszer meg tudja válaszolni:

- ki vagy mi kezdeményezte az eseményt;
- mikor és honnan történt;
- milyen erőforrást érintett;
- milyen művelet történt;
- sikeres vagy sikertelen volt-e;
- milyen kapcsolódó események előzték meg vagy követték.

Naplóforrások Biztonsági üzemeltetésben fontos naplóforrások:

- operációs rendszer naplók;
- alkalmazásnaplók;
- hitelesítési és jogosultsági naplók;
- hálózati eszközök syslog eseményei;
- tűzfal, VPN, WAF, IDS/IPS riasztások;
- felhőszolgáltatók auditlogjai;
- adatbázis-hozzáférési naplók;
- végpontvédelmi és EDR-események.

Az audit policy határozza meg, hogy mely eseményeket kell rögzíteni. Tipikus példa a sikeres és sikertelen bejelentkezés, jogosultságváltoztatás, adminisztrátori művelet, konfigurációmódosítás vagy érzékeny adathozzáférés.

Bizonyítéki érték és naplóvédelem A naplózás értéke annyi, amennyire a napló megbízható. Incidens esetén a támadó gyakran megpróbálja törölni vagy módosítani a terhelő bejegyzéseket. Ezért a naplók védelmének fő követelményei:

- **Integritás:** a napló utólagos módosítása legyen észlelhető.
- **Időhitelesség:** legyen pontos időszinkron, például NTP-vel, védett időforrással.
- **Elkülönített tárolás:** a napló ne csak azon a rendszeren legyen, amelyet a támadó kompromittált.
- **Hozzáférésvédelem:** a naplókat csak korlátozott szerepkörök érhessek el.
- **Megőrzés és törlési rend:** a retention policy feleljen meg üzleti, jogi és adatvédelmi követelményeknek.

Kriptográfiai védelemre használható hash-lánc, digitális aláírás, WORM-tároló vagy elosztott naplózás. A hash-lánc lényege, hogy minden bejegyzés tartalmazza az előző bejegyzés lenyomatát, így egy köztes módosítás a lánc későbbi részét is érvénytelenné teszi.

Naplóelemzés problémái A naplók mennyisége nagy, a bejegyzések jelentős része biztonsági szempontból irreleváns. Emiatt automatizált feldolgozás, normalizálás, korreláció és prioritizálás kell. A gépi tanulás segíthet anomáliák felismerésében, de nem helyettesíti az üzleti kontextust és a szakértői értelmezést. A vizualizáció abban segít, hogy az operátor figyelme a legfontosabb eseményekre irányuljon.

Biztonságos üzemeltetés

SOC, IDS/IPS, SIEM és SOAR A biztonságos üzemeltetés célja, hogy a szervezet folyamatosan képes legyen fenyegetéseket észlelni, elemezni, kezelni és a működést helyreállítani. Ennek intézményi formája gyakran a **Security Operations Center (SOC)**, amely technológiát, folyamatot és emberi elemzői munkát kapcsol össze.

Fontos komponensek:

- **IDS:** behatolásészlelő rendszer; eseményekből vagy hálózati forgalomból riasztást generál.
- **IPS/IDPS:** behatolásmegelőző rendszer; inline módon forgalmat is blokkolhat.
- **SIEM:** biztonsági információ- és eseménymenedzsment; naplókat gyűjt, normalizál, korrelál és riaszt.
- **SOAR:** security orchestration, automation and response; automatizált válaszleépéseket, playbookokat és integrációkat kezel.
- **CTI:** cyber threat intelligence; külső és belső fenyegetési információkat ad, például IOC-eket, TTP-eket, sérülékenységi adatokat.

A SIEM egyik fontos feladata az alert-korreláció: csökkenti az elemzőre zúduló riasztások számát, kontextust ad, összeköti az összefüggő eseményeket, és kiszűri a hamis pozitív riasztásokat.

Architekturális szempontok Üzemeltetési szempontból a védelmi architektúrának nem szabad kizárólag peremvédelmi eszközökre, például tűzfalra épülnie. A DMZ, hálózati szegmentáció, végpontvédelem, naplógyűjtés, sérülékenységmentedzsment és hozzáférésvezérlés együtt ad értelmezhető védelmet.

Tipikus architekturális elvek:

- kritikus rendszerek elkülönítése;
- menedzsment interfészek külön védelme;
- minimális jogosultság elve;
- változáskezelés és konfigurációmenedzsment;
- mentések rendszeres tesztelése;
- sérülékenységek prioritizált javítása;
- incidensre kész kommunikációs és döntési rend.

Incidenskezelés

Az incidens fogalma Biztonsági incidensnek tekinthető minden olyan esemény vagy eseménysorozat, amely sérti vagy veszélyezteti a bizalmasságot, sértetlenséget, rendelkezésre állást, hitelességet vagy az üzleti működés folytonosságát. Nem minden riasztás incidens, és nem minden incidens jelent azonos súlyosságú kockázatot.

Incidentskezelési életciklus Az órai anyag három nagy tevékenységet emel ki: felkészülés, kezelés, lezárás utáni tanulás. Ezek részletesen:

1. **Felkészülés:** szabályzatok, szerepkörök, CSIRT vagy incidenskezelő csapat, kommunikációs csatornák, kontaktlista, eszközök, naplózás, mentések, gyakorlatok.
2. **Észlelés és elemzés:** riasztások, naplók, felhasználói bejelentések és CTI alapján annak eldöntése, történt-e incidens, mi az érintett kör, mi a súlyosság.
3. **Korlátozás:** a további kár megakadályozása, például hálózati izolációval, fiókletiltással, tűzfalszabállyal vagy szolgáltatás ideiglenes leállításával.
4. **Felszámolás:** rosszindulatú kód, támadói hozzáférés, sérülékeny konfiguráció vagy kompromittált hitelesítő adat eltávolítása.
5. **Helyreállítás:** rendszerek visszaállítása, fokozott monitorozás és óvatos visszakapcsolás.
6. **Utókövetés:** tanulságok, jelentés, kontrollok javítása, képzés, playbookok frissítése.

Az incidenskezelés nem tisztán technikai feladat. Jogi, kommunikációs, vezetői, adatvédelmi és üzletmenet-folytonossági döntéseket is igényel. Különösen fontos, hogy a szervezet előre tudja, mikor kell hatóságot, ügyfelet, partnert vagy felügyeleti szervet értesíteni.

Bizonyítékkezelés Incidensnél a bizonyítékok minősége döntő. A bizonyítékkezelés során figyelni kell:

- a bizonyíték forrására és integritására;
- a hozzáférési láncre, vagyis ki, mikor, mit kezelt;
- a változtatásmentes mentésre;
- a naplók, memóriaképek, lemezképek és hálózati forgalmak időbeli összekapcsolására;
- arra, hogy a helyreállítás ne törölje el a vizsgálathoz szükséges adatokat.

MAPE-K modell

A modell jelentése A MAPE-K az autonóm és biztonsági üzemeltetésben használt visszacsatolási modell:

- **Monitor:** adatgyűjtés eseményekből, naplók, hálózati forgalomból, végpontokból, alkalmazásokból.
- **Analyze:** a begyűjtött nyomok értelmezése, anomália- és visszaélésdetektálás, riasztásminősítés.
- **Plan:** válaszstratégia kiválasztása, priorizálás, döntéstámogatás.
- **Execute:** ellenintézkedések végrehajtása, például blokkolás, izoláció, fiókletiltás, szabálmódosítás.

- **Knowledge:** tudásbázis, sérülékenységi adatbázis, playbookok, fenyegetési intelligencia, tanulságok.

MAPE-K a biztonsági üzemeltetésben A MAPE-K jól megfeleltethető a SOC működésének. A Monitor réteghez tartoznak a szenzorok, naplók és adatfolyamok. Az Analyze réteghez tartozik a detektálási logika, például signature-alapú vagy anomália-alapú elemzés. A Plan rétegben a SIEM és döntéstámogató folyamatok segítenek meghatározni, hogy a riasztás valódi incidens-e és milyen válasz kell. Az Execute rétegben az IDPS, tűzfal, EDR vagy SOAR végrehajtja a kiválasztott lépéseket. A Knowledge réteghez tartozik a CTI, CVE, CVSS, CWE, CERT/CSIRT ajánlások, ISAC információmegosztás és a szervezeti tanulságok.

MAPE-K elem	Biztonsági példa	Kockázat
Monitor	Syslog, EDR, NetFlow, alkalmazásnapló, felhő audit-log	Hiányos vagy manipulált naplózás
Analyze	Korreláció, anomáliadetektálás, IOC-illesztés	Hamis pozitív és hamis negatív riasztások
Plan	Incidensprioritás, playbook kiválasztása	Lassú döntés vagy rossz súlyossági besorolás
Execute	IP-blokkolás, host izoláció, fiókletiltás	Üzleti működés indokolatlan megszakítása
Knowledge	CTI, CVE/CVSS/CWE, tanulságok	Elavult tudásbázis, nem frissített playbook

1. táblázat. MAPE-K elemek biztonsági üzemeltetési értelmezése

Rendeletek és szabványok

Európai és magyar szabályozási környezet GDPR. Az általános adatvédelmi rendelet a személyes adatok kezelésére vonatkozik. Incidenskezelésben különösen fontos a személyes adat megsértésének bejelentése: ha az incidens valószínűsíthetően kockázattal jár az érintettek jogaira és szabadságaira, a felügyeleti hatóságot indokolatlan késedelem nélkül, lehetőség szerint 72 órán belül értesíteni kell. Magas kockázat esetén az érintettek tájékoztatása is szükséges lehet.

NIS2. A NIS2 irányelv célja az EU egészében magas közös kiberbiztonsági szint kialakítása. A tagállamoknak 2024. október 17-ig kellett átültetniük, a szabályok 2024. október 18-tól alkalmazandók. Lényeges és fontos szervezetekre ír elő kockázatkezelési, incidensbejelentési, vezetői felelősségi és beszállítói biztonsági követelményeket.

DORA. A Digital Operational Resilience Act a pénzügyi szektor digitális működési ellenálló képességét szabályozza. 2025. január 17-től alkalmazandó. Fő pillérei:

IKT-kockázatkezelés, incidensjelentés, digitális működési reziliencia tesztelése, harmadik fél IKT-kockázat kezelése és információmegosztás.

Magyar kiberbiztonsági szabályozás. Magyarországon a NIS2-höz kapcsolódó jelenlegi központi jogszabály a Magyarország kiberbiztonságáról szóló 2024. évi LXIX. törvény és annak végrehajtási rendeletei, például a 418/2024. (XII. 23.) Korm. rendelet. Ezek az elektronikus információs rendszerek kockázatarányos védelméhez, hatósági felügyeletéhez, nyilvántartási és auditkövetelményeihez kapcsolódnak.

Szabványok és ajánlások

- **ISO/IEC 27001:2022:** információbiztonsági irányítási rendszer követelményei; kockázatalapú, tanúsítható menedzsmentrendszer.
- **ISO/IEC 27002:2022:** információbiztonsági kontrollok gyakorlati katalógusa.
- **ISO/IEC 27005:** információbiztonsági kockázatmenedzsment.
- **ISO/IEC 27035:** információbiztonsági incidenskezelés.
- **ISO/IEC 27701:** adatvédelmi információmenedzsment, GDPR-megfelelés támogatása.
- **NIST Cybersecurity Framework 2.0:** Govern, Identify, Protect, Detect, Respond, Recover funkciók köré szervezett kiberbiztonsági keretrendszer.
- **NIST SP 800-61 Rev. 3:** incidensválasz ajánlások a kiberbiztonsági kockázatmenedzsment részeként; 2025-ben véglegesített revízió, amely felváltotta a Rev. 2-t.
- **NIST SP 800-63:** digitális identitás és felhasználó-hitelesítés irányelvei.
- **PCI DSS:** fizetési kártyaadatok kezelésére vonatkozó iparági követelményrendszer.

A szabványok és rendeletek viszonya: a jogszabály kötelező követelményt ad, a szabvány pedig módszertant, kontrollkatalógust és bizonyítási keretet. Egy szervezet például ISO/IEC 27001 szerinti ISMS-sel tudja megszerezni a GDPR, NIS2 vagy DORA által megkövetelt kockázatkezelési, naplózási és incidenskezelési kontrollokat.

Vizsgán mondható összefoglaló

A hitelesítés az állított identitás ellenőrzése; a feljogosítás azt dönti el, hogy a hitelesített entitás mire jogosult; a naplózás pedig biztosítja az utólagos elszámoltathatóságot. A felhasználó-hitelesítés tudás-, birtoklás- és biometrikus faktorokra épülhet, de kritikus rendszerekben többfaktoros, adathalászatnak ellenálló megoldás szükséges.

Elosztott rendszerekben a hitelesítés fő problémája a bizalmi határok átlépése. A Kerberos jegyekkel és session keyekkel biztosít kölcsönös hitelesítést, míg az OAuth 2.0 és az OpenID Connect tokenalapú, webes és API-központú környezetben használható. Föderált identitásnál egy identitásszolgáltató állításait fogadják el a szolgáltatások.

A nyomkövethetőség naplókon, audit trailen, időbélyegeken és védett bizonyítékokon alapul. A naplókat védeni kell módosítás és törlés ellen, különben incidensnél nem lesz bizonyító erejük. A biztonságos üzemeltetés SOC, SIEM, IDS/IPS, SOAR és CTI eszközökkel valósítja meg a folyamatos észlelést és reagálást.

A MAPE-K modell a biztonsági működés visszacsatolási ciklusa: monitorozunk,

elemzünk, tervet készítünk, végrehajtunk, majd a tudásbázist frissítjük. Az incidenskezelés ugyanezt szervezeti folyamatként valósítja meg: felkészülés, észlelés, elemzés, korlátozás, felszámolás, helyreállítás és tanulságok beépítése. A GDPR, NIS2, DORA, ISO/IEC 27001, ISO/IEC 27035 és NIST ajánlások adják azt a jogi és szakmai keretet, amelyben mindezt bizonyíthatóan működtetni kell.

1.3. 3. tétel: gépi tanulási alapismeretek

Felügyelt- és nem felügyelt tanulás; Egy és többváltozós lineáris regresszió; Gradiens csökkenési eljárás; Sztochasztikus és mini-batch gradiens csökkentés; Leírók normálása; Polinomiális regresszió; Normál egyenlet; Logisztikus regresszió; Két- és többosztályos osztályozás; Regularizáció (alul- és túltanulás); Regularizált lineáris és logisztikus regresszió; Neurális hálók; Backpropagation algoritmus; Numerikus gradiensellenőrzés.

Felügyelt tanulás. Egy adott adathalmaz esetén már tudjuk, hogyan kellene kinéznie a helyes kimenetnek, és rendelkezünk azzal az információval, hogy van valamilyen kapcsolat a bemenet és a kimenet között. A felügyelt tanulási problémákat két kategóriába soroljuk: 'REGRESSZIÓ', ahol egy folytonos kimeneten belüli eredményt próbálunk megjósolni (vagyis a bemeneti változókat egy folytonos függvényhez rendeljük), vagy 'OSZTÁLYOZÁS', ahol a bemeneti változókat diszkrét kategóriákba próbáljuk sorolni.

Nem felügyelt tanulás. Kevés vagy semennyi elképzelésünk sincs arról, hogyan kellene kinézniük az eredményeknek. Az adatok szerkezetéről úgy kaphatunk információt, hogy a változók közötti kapcsolatok alapján klaszterezük azokat.

Lineáris regresszió (egyváltozós). Az egyváltozós lineáris regressziót akkor használjuk, ha egyetlen bemeneti értékből (x) egyetlen kimeneti értéket (y) szeretnénk megjósolni. A hipotézisfüggvény általános alakja:

$$\hat{y} = h_{\theta}(x) = \theta_0 + \theta_1 x$$

A cost function segítségével mérhetjük a hipotézisfüggvény pontosságát:

$$J = \frac{1}{2m} \sum_{i=1}^m (h_{\theta}(x_i) - y_i)^2$$

A hipotézisfüggvény paramétereinek becsléséhez a *Gradient Descent*-et használjuk. A θ_0 -t az x-tengelyre, a θ_1 -et az y-tengelyre, a költségfüggvényt pedig a függőleges z-tengelyre helyezzük. A grafikon pontjai a költségfüggvény eredményei az adott θ paraméterekkel rendelkező hipotézis mellett. A költségfüggvény grafikonjának minimumát keressük. Ehhez kiszámítjuk a költségfüggvény deriváltját; az érintő meredeksége az adott pont deriváltja, ami megadja a haladási irányt. α nagyságú lépéseket teszünk a legmeredekebb ereszkedés irányába. Ismételjük a konvergenciáig:

$$\theta_0 := \theta_0 - \alpha \frac{1}{m} \sum_{i=1}^m (h_{\theta}(x_i) - y_i)$$

$$\theta_1 := \theta_1 - \alpha \frac{1}{m} \sum_{i=1}^m ((h_\theta(x_i) - y_i)x_i)$$

Lineáris regresszió (többváltozós). A hipotézisfüggvény többváltozós alakja:

$$h_\theta = \theta_0 + \theta_1 x_1 + \theta_2 x_2 + \dots + \theta_n x_n$$

Mátrixszorzást használva a függvény felírható $\theta^\top x$ alakban. A költségfüggvény:

$$J = \frac{1}{2m} \sum_{i=1}^m (h_\theta(x^{(i)}) - y^{(i)})^2$$

A gradient descent pedig (ismételjük a konvergenciáig):

$$\theta_j := \theta_j - \alpha \sum_{i=1}^m (h_\theta(x^{(i)}) - y^{(i)}) \cdot x_j^{(i)}$$

Sztochasztikus csökkentés. A klasszikus gradiens leereszkedés alternatívája, amely jóval hatékonyabb nagy adathalmazok esetén.

$$\text{cost}(\theta, (x^{(i)}, y^{(i)})) = \frac{1}{2} (h_\theta(x^{(i)}) - y^{(i)})^2$$

A sztochasztikus módszer lényege éppen az, hogy minden egyes (i) tréningpélda után azonnal frissítjük a paramétereket, így nem kell megvárunk a teljes adathalmaz feldolgozását egyetlen lépéshez.

$$\theta_j := \theta_j - \alpha (h_\theta(x^{(i)}) - y^{(i)}) \cdot x_j^{(i)}$$

Mini-batch gradiens csökkentés. Ahelyett, hogy az összes m példát használnánk (mint a klasszikus módszernél), vagy csupán egyetlen példát (mint a sztochasztikus módszernél), egy köztes értéket, b számú példát használunk egyszerre.

$$\theta_j := \theta_j - \alpha \frac{1}{b} \sum_{k=i}^{i+b-1} (h_\theta(x^{(k)}) - y^{(k)}) x_j^{(k)}$$

Leírók normálása. A gradient descent felgyorsítása érdekében az értékeinket nagyjából azonos tartományba transzformálhatjuk. Ehhez először elosztjuk a bemeneti értékeket a terjedelemmel (így az új tartomány 1 lesz), másodszor pedig kivonjuk az átlagértéket a bemeneti változóból:

$$x_i = \frac{x_i - \mu_i}{s_i}$$

ahol μ_i az összes érték átlaga, s_i pedig az értékek terjedelme (maximum – minimum).

Polinomiális regresszió. A hipotézisfüggvénynek nem kell feltétlenül lineárisnak lennie, ha az nem illeszkedik jól az adatokra. Ha a hipotézisfüggvényünk $h_\theta(x) = \theta_0 + \theta_1 x_1$, akkor létrehozhatunk további jellemzőket x_1 alapján, hogy megkapjuk például a másodfokú (kvadrátikus) függvényt:

$$h_\theta(x) = \theta_0 + \theta_1 x_1 + \theta_2 x_1^2$$

Normál egyenlet. Ez egy módszer az optimális θ meghatározására iteráció (ismétlés) nélkül.

$$\theta = (X^T X)^{-1} X^T y$$

Logisztikus regresszió – bináris osztályozás. Ahelyett, hogy a kimeneti vektorunk (y) folytonos értékeket venne fel, az értéke 0 vagy 1. Az egyik módszer az lenne, hogy lineáris regressziót használunk, és minden 0,5-nél nagyobb becslést 1-nek, a kisebbet pedig 0-nak tekintenénk. Ez azonban nem működik jól, mert az osztályozás nem lineáris függvény. A hipotézisünk tartománya: $0 \leq h_\theta(x) \leq 1$.

$$h_\theta(x) = g(\theta^T x)$$

$$z = \theta^T x$$

$$g(z) = \frac{1}{1 + e^{-z}}$$

A $g(z)$ függvény bármely valós számot a $(0, 1)$ intervallumra képez le.

$$h_\theta(x) \geq 0.5 \rightarrow y = 1$$

$$h_\theta(x) < 0.5 \rightarrow y = 0$$

A költségfüggvénynek két feltételes esete van:

$$J = -\frac{1}{m} \sum_{i=1}^m [y^{(i)} \log(h_\theta(x^{(i)})) + (1 - y^{(i)}) \log(1 - h_\theta(x^{(i)}))]$$

Ha $y = 1$, a második tag 0 lesz, így nem befolyásolja az eredményt. Ha $y = 0$, az első tag lesz 0, így az nem hat az eredményre.

Gradient descent:

$$\theta_j := \theta_j - \frac{\alpha}{m} \sum_{i=1}^m (h_\theta(x^{(i)}) - y^{(i)}) x_j^{(i)}$$

Többosztályos osztályozás (One-vs-All). Az $y = \{0, 1\}$ helyett kiterjesztjük az értelmezést úgy, hogy $y = \{0, 1, \dots, n\}$. A problémát $n + 1$ darab bináris osztályozási feladatra bontjuk, ahol mindegyiknél azt a valószínűséget becsüljük meg, hogy az y az adott osztály tagja-e.

$$y \in \{0, 1, \dots, n\}$$

$$h_\theta^{(0)}(x) = P(y = 0|x; \theta)$$

$$h_\theta^{(1)}(x) = P(y = 1|x; \theta)$$

$$\vdots$$

$$h_\theta^{(n)}(x) = P(y = n|x; \theta)$$

$$\text{predikció} = \max_i (h_\theta^{(i)}(x))$$

Regularizáció.

- *Alultanulás (Underfitting / High Bias)*. Akkor beszélünk róla, ha a h hipotézisfüggvény alakja rosszul illeszkedik az adatok trendjére. Ez általában akkor fordul elő, ha a függvény túl egyszerű, vagy túl kevés jellemzőt (feature) használunk. Ebben az esetben a modell nem képes megtanulni az adatokban lévő összefüggéseket.
- *Tútanulás (Overfitting / High Variance)*. Akkor következik be, ha a hipotézisfüggvény túlságosan szorosan illeszkedik a meglévő adathalmazra, de nem képes jól generalizálni (általánosítani) az új adatokra. Ezt általában egy túlságosan összetett függvény okozza, amely felesleges görbéket és töréseket hoz létre, amiknek nincs közük a valódi adatokhoz, csupán a zajt tanulták meg.

A tútanulás kezelésére két fő utunk van:

- a) A jellemzők számának csökkentése (manuálisan vagy algoritmus segítségével).
- b) Regularizáció alkalmazása: Megtartjuk az összes jellemzőt, de csökkentjük a paraméterek (θ_j) nagyságát/hatását.

A λ a regularizációs paraméter. Ez határozza meg, hogy mennyire "büntetjük" (infláljuk) a θ paraméterek költségét. Ha a λ értéke túl nagy, az a modell alultanuláshoz (underfitting) vezethet, mivel a paramétereket túlságosan "lelápítja". Ha viszont túl kicsi, nem küszöböli ki hatékonyan a tútanulást (overfitting).

Regularizált lineáris regresszió. Költségfüggvény:

$$J(\theta) = \underbrace{\frac{1}{2m} \sum_{i=1}^m (h_{\theta}(x^{(i)}) - y^{(i)})^2}_{\text{Hiba}} + \underbrace{\frac{\lambda}{2m} \sum_{j=1}^n \theta_j^2}_{\text{Büntetés}}$$

A gradient descent regularizációval kiegészített alakja:

$$\begin{aligned} \theta_0 &:= \theta_0 - \alpha \frac{1}{m} \sum_{i=1}^m (h_{\theta}(x^{(i)}) - y^{(i)}) x_0^{(i)} \\ \theta_j &:= \theta_j - \alpha \left[\left(\frac{1}{m} \sum_{i=1}^m (h_{\theta}(x^{(i)}) - y^{(i)}) x_j^{(i)} \right) + \frac{\lambda}{m} \theta_j \right] \end{aligned}$$

Regularizált logisztikus regresszió. Költségfüggvény:

$$J = -\frac{1}{m} \sum_{i=1}^m [y^{(i)} \log(h_{\theta}(x^{(i)})) + (1 - y^{(i)}) \log(1 - h_{\theta}(x^{(i)}))] + \frac{\lambda}{2m} \sum_{j=1}^n \theta_j^2$$

Gradient descent:

$$\begin{aligned} \theta_0 &:= \theta_0 - \alpha \frac{1}{m} \sum_{i=1}^m (h_{\theta}(x^{(i)}) - y^{(i)}) x_0^{(i)} \\ \theta_j &:= \theta_j - \alpha \left[\left(\frac{1}{m} \sum_{i=1}^m (h_{\theta}(x^{(i)}) - y^{(i)}) x_j^{(i)} \right) + \frac{\lambda}{m} \theta_j \right] \end{aligned}$$

Neurális hálók. A Neurális hálók rétegzett struktúrájú matematikai modellek, amelyek képesek mintázatok felismerésére és nemlineáris összefüggések modellezésére.

- **Bemeneti réteg (Input layer):** Ez a réteg fogadja az adatokat, azaz a bemeneti jellemzőket (feature-öket). Minden neuron egy-egy bemeneti változót reprezentál.
- **Rejtett rétegek (Hidden layers):** Ezek a bemeneti és kimeneti réteg közötti rétegek, ahol a tényleges számítások zajlanak. Több rejtett réteg esetén mély neurális hálózatról (deep neural network) beszélünk.
- **Kimeneti réteg (Output layer):** Ez a réteg adja a modell végső kimenetét, például osztályozási címkét vagy regressziós becslést.

Minden réteg neuronokból áll, amelyek alapvető számítási egységek. Egy neuron a bemenetek súlyozott összegét számítja ki, majd ezt egy aktivációs függvényen keresztül továbbítja. Matematikailag egy neuron működése a következőképpen írható le:

$$z = \sum_{i=1}^n w_i x_i + b, \quad a = \phi(z),$$

ahol w_i a súlyok, x_i a bemenetek, b a bias, és ϕ az aktivációs függvény (pl. szigmoid, ReLU, tanh).

Forward propagation: Az a folyamat, amely során a bemeneti adatokat rétegről rétegre továbbítjuk a hálózatban, amíg el nem jutunk a kimenethez. Minden neuron kiszámítja a súlyozott bemeneti összeget, majd alkalmazza az aktivációs függvényt. Ez határozza meg a hálózat aktuális predikcióját.

Tanítás: A neurális hálózat tanítása iteratív optimalizációs folyamat, amelynek célja a modell paramétereinek (súlyok és biasok) finomhangolása a veszteségfüggvény minimalizálása érdekében.

- **Paraméterek inicializálása:** A súlyok és biasok kezdeti értékeinek beállítása (általában véletlenszerűen).
- **Előreterjesztés:** A bemenetek feldolgozása és a predikciók kiszámítása.
- **Költségfüggvény (loss) számítása:** A predikció és a valós érték közötti eltérés mérése (pl. MSE, cross-entropy).
- **Visszaterjesztés (Backpropagation):** A gradiens kiszámítása a láncszabály alkalmazásával, amely megmutatja, hogyan kell módosítani a paramétereket.
- **Paraméterfrissítés:** A súlyok és biasok frissítése egy optimalizáló algoritmus (pl. gradienscsökkenés, Adam) segítségével.

Backpropagation: A visszaterjesztés a neurális hálózatok tanításának kulcsfontosságú algoritmus, amely a paraméterek (súlyok és biasok) frissítésére szolgál a költségfüggvény minimalizálása érdekében. Az eljárás a differenciálszámítás láncszabályán (chain rule) alapul, amely lehetővé teszi a költségfüggvény gradiensének hatékony kiszámítását minden egyes paraméterre vonatkozóan.

Formálisan legyen L a költségfüggvény, w egy adott súly, és b egy bias. A cél a $\frac{\partial L}{\partial w}$ és $\frac{\partial L}{\partial b}$ deriváltak meghatározása. A hálózat réteges felépítése miatt ezek a deriváltak egymásba ágyazott függvényekből állnak, így a láncszabály alkalmazásával számíthatók ki:

$$\frac{\partial L}{\partial w} = \frac{\partial L}{\partial a} \cdot \frac{\partial a}{\partial z} \cdot \frac{\partial z}{\partial w},$$

ahol z a neuron bemeneti összege, a pedig az aktiváció.

A visszaterjesztés során a hibát (loss gradiensét) a kimeneti rétegtől indulva visszafelé terjesztjük a hálózaton keresztül, rétegről rétegre. Minden réteg esetén kiszámítjuk az ún. hibatermet (error term vagy δ), amely megmutatja, hogy az adott neuron milyen mértékben járult hozzá a teljes hibához.

A tanulási lépés során a paramétereket tipikusan gradienstsökkenéssel (gradient descent) frissítjük:

$$w := w - \alpha \frac{\partial L}{\partial w}, \quad b := b - \alpha \frac{\partial L}{\partial b},$$

ahol α a tanulási ráta (learning rate), amely szabályozza a frissítés mértékét.

2. Az adattudomány gyakorlati hátteréhez kapcsolódó alapismeretek.